AUDITORÍA TÉCNICA · SEGURIDAD · BACKEND · FRONTEND · UI/UX

Desamparados — Auditoría integral

Portal web de la Hermandad de Nuestra Señora de los Desamparados (Málaga): API Node/Express/Prisma y frontend React/MUI. Revisión de seguridad, lógica de negocio, calidad de código, accesibilidad, SEO y rendimiento — con explotación verificada en un entorno real levantado para la ocasión.

Ámbito: ~12.800 líneas · 2 paquetes

Método: lectura línea a línea + stack en vivo (MariaDB + API + web) + navegador real **Fecha:** 24 ago 2026

Commit: ffa589d (import inicial)

Veredicto

Son **dos proyectos maduros pero desconectados**. El **backend** está sorprendentemente bien fortificado (Helmet, rate-limit, 2FA, auditoría, RGPD, validación en casi todas las rutas)… salvo **un agujero crítico que tira todo lo demás**: un **mass assignment** que permite a cualquier hermano ascenderse a ADMIN y falsear pagos — **lo confirmé explotándolo en vivo**. El **frontend** es visualmente cuidado pero **no está conectado a la API** (0 llamadas reales, todo son mocks y credenciales de prueba); además las noticias enlazan a una ruta que no existe y devuelven al usuario a la portada.

No es publicable tal cual. Con una semana de trabajo enfocado (cerrar el mass assignment, cablear el frontend al backend, y limpiar datos legales/placeholder) queda en un estado sólido para producción.

5	30	66	87	29
CRÍTICAS	ALTAS	MEDIAS	BAJAS	MEJORAS

~217 hallazgos agregados de 3 auditorías (backend seguridad/dominio, backend CMS/subidas, frontend) + verificación en vivo. Abajo se detallan las críticas y altas; medias/bajas van resumidas por tabla.

00 Explotado en vivo

Levanté el stack completo (MariaDB portable + API + web) y ejecuté los ataques contra la base de datos real. Estos dos no son teoría: los reproduje y comprobé el efecto en la BD.

Escalada a ADMIN y fraude económico por *mass assignment*

CONFIRMADO

`backend · PUT /api/hermanos/mis-perfiles/:id · services/hermano.service.ts:433-443`

La validación ArkType **conserva las claves no declaradas** del body y el servicio reenvía el objeto entero a `db.hermano.update()`, que acepta escrituras a relaciones anidadas. Cualquier **USER autenticado**, editando su propia ficha, puede tocar la tabla `User` y `Recibo`.

REPRODUCCIÓN con el usuario de prueba `hermano@cofradia.com` (rol USER):

```
# 1) Autoascenderse a ADMIN
PUT /api/hermanos/mis-perfiles/1
{"nombre":"Juan","user":{"update":{"role":"ADMIN"}}}
→ 200 OK   // en BD: user.role pasa de USER a ADMIN

# 2) Marcar TODOS mis recibos como pagados
PUT /api/hermanos/mis-perfiles/1
{"recibos":{"updateMany":{"where":{},"data":{"estado":"PAGADO"}}}}
→ 200 OK   // recibo pendiente de 30€ → PAGADO

# 3) Falsear antigüedad y nº de hermano
{"numeroHermano":1,"fechaAlta":"1950-01-01","tieneTunicaPropia":true}
→ 200 OK
```

IMPACTO compromiso total del sistema: acceso a censo, tesorería, roles y configuración; fraude directo sobre recibos y papeletas; una SECRETARIA podría además reescribir la contraseña o el 2FA de cualquier hermano (`{"user":{"update":{"password":"..."}}}`) y tomar su cuenta.

Arreglo construir el objeto de update por **lista blanca** (nunca `{...data}`) y activar `onUndeclaredKey:"delete"` / `"+": "delete"` en ArkType a nivel global para que descarte claves no declaradas en todas las rutas. Es la corrección nº 1, de dos líneas.

Fuga de hash de contraseña, secreto 2FA, token de reset e IBAN en el panel de solicitudes

CONFIRMADO

`backend · GET /api/hermanos/admin/solicitudes · services/hermano.service.ts:333-345`

El endpoint hace `include:{hermanos:true}` sin `select` y devuelve el objeto `User` completo. Verificado en vivo — la respuesta a ADMIN/SECRETARIA incluye literalmente:

```
password:          "$2a$10$HASHSECRETO…"    ← hash bcrypt
twoFactorSecret:   "JBSWY3DPEHPK3PXP"       ← secreto TOTP reutilizable
resetPasswordToken:"tok-reset-secreto-999" ← toma de cuenta
hermanos[0].iban: "ES9121000418450200051332"
```

IMPACTO el secreto 2FA permite generar códigos válidos indefinidamente incluso tras aprobar la cuenta; el token de reset permite secuestrarla. Fuga de datos bancarios (RGPD).

Arreglo reemplazar `include` por un `select` explícito sin secretos; añadir `omit: {password,twoFactorSecret,resetPasswordToken}` a nivel de cliente Prisma como red de seguridad.

01 Seguridad del backend

Más allá de los dos confirmados, la revisión de autorización, subidas y CMS encontró varios altos. La buena noticia: la base defensiva (rate-limit, JWT con algoritmo fijado, revalidación de sesión contra BD, lockout por cuenta, sanitización HTML) está bien hecha.

El antivirus de subidas (ClamAV) está roto de dos formas: rechaza todo archivo limpio y trunca el stream

ALTA

`utils/clamd.ts:49-77`

Dos bugs encadenados: (1) clamd responde `stream: OK` pero el código comprueba `resp.startsWith('OK')` → siempre cae en la rama "infectado"; (2) el `return` dentro del bucle de escritura, sin listener `drain`, corta el envío al primer backpressure y el análisis expira a los 20 s. Si se activa ClamAV siguiendo el propio `SECURITY.md`, **ninguna subida legítima pasa**.

Arreglo `if(/(^|:\s*)OK$/.test(resp))` y escribir el buffer con `await` por trozo (o `stream.pipeline`). Cubrir con un test que levante un clamd falso.

La recuperación de contraseña está rota de origen: el email lleva una URL dentro de otra

ALTA

`services/auth.service.ts:317-321 + email.service.ts:91-92`

`auth.service` construye `resetUrl = FRONTEND_URL/reset-password?token=HEX` y se lo pasa a `enviarRecuperacionContrasena`, que **vuelve a envolverlo** en otra URL. El enlace final es `…?token=https://…?token=HEX` y nunca coincide con el token guardado.

Arreglo pasar `resetToken` (no la URL ya montada) y `encodeURIComponent` en la plantilla. Latente hoy porque el frontend aún no tiene página de reset.

Los borradores de noticias son públicos

ALTA

`GET /api/news/archive · services/news.service.ts:49-57`

El archivo público no filtra `visible:true` (un comentario admite que "se asume que es para admin"). `GET /api/news/archive?limit=1000` devuelve todos los borradores con su contenido íntegro a cualquier visitante.

Arreglo forzar `visible:true` en la ruta pública; crear una ruta admin aparte para borradores.

Secretaría puede bloquear (y borrar) la cuenta del ADMIN; un staff puede autobloquearse

ALTA

`services/hermano.service.ts:311-319, 423-425`

Las bajas y el rechazo de solicitudes no comprueban `user.role`. Dar de baja la ficha titular de un ADMIN pone su cuenta `active:false` (pierde el acceso en la siguiente petición) y luego "rechazar" hace `user.delete`. **Confirmé empíricamente** el caso benigno: al borrar mi propia ficha titular, mi cuenta USER quedó inactiva y dejó de poder entrar ("pendiente de aprobación").

Arreglo desactivar/borrar solo si `role === USER`; exigir confirmación para la baja de la ficha titular propia.

Lo que sí está bien (verificado en vivo): IDOR correctamente bloqueado (403 al tocar fichas/recibos ajenos), `mis-recibos` acotado al usuario, JWT con `alg=none` rechazado, roles aplicados (403 de USER en rutas admin), cabeceras Helmet completas (CSP, HSTS, nosniff, frameguard), rate-limit activo (`RateLimit: limit=100`), validación de DNI/contraseña, sanitize-html neutraliza `<script>`/`javascript:`/`onerror`, y noticias con `visible:false` ocultas en `/latest`.

OTRAS (MEDIAS/BAJAS) DE SEGURIDAD BACKEND

SEV.	HALLAZGO	DÓNDE
Media	Mass assignment también en inventario (prendas/enseres) por roles gestores	`inventario.service.ts:102,110`
Media	`POST /api/pages` es un `upsert`: sobrescribe páginas protegidas (aviso legal)	`pagina.service.ts:41-53`
Media	`PUT /api/pages/:slug` con schema laxo admite `<img onerror>` en el título	`pagina.routes.ts:11-16`
Media	Agenda usa un `optionalAuth` débil (sin BD): tokens revocados siguen viendo eventos privados	`middleware/optionalAuth.ts`
Media	Config sin tipado por clave: precios pueden guardarse como texto no numérico	`admin.service.ts:111-124`
Media	`/prendas` expone a cualquier hermano quién tiene cada prenda (nombre, nº)	`inventario.service.ts:91-94`

SEV.	HALLAZGO	DÓNDE
Baja	PDFs servidos *inline* desde el origen de la API (sin `Content-Disposition`)	`app.ts:72`
Baja	Archivo escrito en `/storage` (público) antes de verificarlo; sin limpieza de huérfanos	`upload.middleware.ts:12-23`
Baja	Carrera en `demote` mutuo → sistema sin ningún ADMIN	`admin.service.ts:72-76`
Baja	Inyección en logs con `file.originalname` / emails en `console.log` (PII)	`upload.controller.ts:55`

02 Lógica de negocio y datos

El dominio (recibos, papeletas, procesión, censo) tiene bugs que afectan a dinero y a datos personales. Nota estructural: **los módulos `procesion` y `transaccion` existen pero no están montados** en `app.ts` — verificado con 404 en vivo. Es código muerto hasta que se enganchen (y varios de estos bugs saltarán al hacerlo).

Errores de negocio convertidos en HTTP 500 genéricos en todo el backend

ALTA

`controllers/*.controller.ts (catch) + utils/error.handle.ts`

Cada controlador captura el error y responde 500 "Error interno", así que el `globalErrorHandler` (que sí mapea 400/404/409) nunca se alcanza. ~40 reglas de negocio ("Ya tienes tu papeleta", "DNI duplicado"...) llegan al usuario como 500. El frontend no puede mostrar el motivo real.

Arreglo usar `next(e)` (Express 5 propaga rechazos async) y una clase `HttpError(status,msg)` en los servicios.

Reordenar el censo falla siempre tras la primera baja (colisión de `numeroHermano @unique`)

ALTA

`services/hermano.service.ts:397-407`

Reasigna `numeroHermano = index+1` en updates secuenciales; MySQL comprueba el índice único por sentencia, así que en cuanto el orden cambie (o un baja conserve su número) lanza P2002 → rollback → el proceso anual de Secretaría es inoperable.

Arreglo en una transacción, poner todos los `numeroHermano` a NULL primero y luego reasignar; liberar el número al dar de baja.

Un usuario aprobado puede crear familiares "activos" saltándose a Secretaría

ALTA

`services/hermano.service.ts:57-73`

`POST /mis-perfiles` crea fichas con `activo:true` al instante (el registro normal nace inactivo). Entran al censo, reciben cuotas, y por emancipación generan cuentas `User` activas que nadie aprobó.

Arreglo crear dependientes `activo:false` y mostrarlos en el panel de solicitudes.

DINERO, PAPELETAS Y TURNOS (RESUMEN)

SEV.	HALLAZGO	DÓNDE
Media	Generar cuotas deduplica por texto del concepto y sin lock → doble cobro masivo	`recibo.service.ts:26-35`
Media	`PUT /recibos/admin/:id` salta la máquina de estados: "pagar" un recibo ANULADO, papeletas huérfanas	`recibo.service.ts:170-195`
Media	El cobro no guarda el método de pago (tesorería no cuadra caja)	`recibo.service.ts:119-124`
Media	Cobros/papeletas no generan apunte en `Transaccion`: el balance no refleja ingresos reales	`recibo.service.ts` + `procesion.service.ts`
Media	Precio 0€ imposible: `Number("0")||30` → 30; importes en `float` con redondeo silencioso	`procesion.service.ts:175-179`

SEV.	HALLAZGO	DÓNDE
Media	Una cita `NO_PRESENTADO` bloquea toda nueva reserva del año (contradice el email de aviso)	`procesion.service.ts:63-70`
Media	`anularPapeleta` borra físicamente el histórico y no comprueba año/estado	`procesion.service.ts:254-284`
Baja	Cobro de recibos `EXENTO`; doble cobro concurrente sin lock (2 emails, 2 auditorías)	`recibo.service.ts:109-124`
Baja	Datos del evento hardcodeados e incoherentes entre los dos emails de papeleta ("Jueves" vs "Viernes Santo")	`recibo.service.ts:150` / `procesion.service.ts:242`
Baja	Fechas con regex de prefijo: `2026-99-99` → *Invalid Date* → 500; `2026-02-31` se guarda como 3 de marzo	`varios schemas`
Baja	Paginaciones sin tope ni saneo (libro mayor, archivo, censo): `?page=-5` → 500, `?limit=1e6` → volcado	`transaccion/news/hermano`

03 Frontend: bugs y arquitectura

El frontend está bien montado (code-splitting, tema centralizado, RHF+zod) pero **no habla con el backend** y tiene un bug de navegación que rompe la sección de noticias.

El frontend no tiene ninguna conexión con el backend

CRÍTICA

`0 fetch · 0 useQuery · 0 VITE_ · 12 imports de mocks`

Verificado por grep: cero `fetch`/`axios`/`useQuery`/`import.meta.env`, `QueryClientProvider` sin consumidores, y los 4 `onSubmit` hacen `console.log` o comparan credenciales hardcodeadas. Todo tira de `src/lib/mocks`. No existe capa de API ni configuración de entorno donde enchufar el backend real.

Arreglo crear `src/lib/api/` (cliente fetch con baseURL, `Authorization: Bearer`, manejo de 401), esquemas zod de respuesta, hooks `useQuery` por recurso, y un `QueryBoundary` (loading/error/vacío). Es el trabajo grande pendiente.

Todas las noticias enlazan a una ruta inexistente → devuelven a la portada

CONFIRMADO

`NewsCard.tsx:26 + routes/index.tsx:96,132`

Las tarjetas enlazan a `/actualidad/noticias/:slug`, ruta que no existe → el comodín `*` hace `Navigate to "/"`. **Confirmado en vivo:** abrir cualquier noticia acaba en `http://localhost:5174/` sin explicación. No hay página de detalle de noticia.

Arreglo crear `NoticiaDetallePage` con ruta `:slug` (y `useParams`+query), y sustituir el comodín por una `NotFoundPage` real.

La animación de secciones está rota en 32 de ~40 páginas (y ensucia la consola en todas)

CONFIRMADO

`AnimatedSection.tsx:16-24 (component override)`

`AnimatedSection` hace `component={motion.section}` pero luego `{...props}`; cuando una página pasa `component="section"` sobrescribe el `motion.section` por un `<section>` plano. **Confirmé en el navegador** el error en cada página: *"React does not recognize the whileInView prop"*, y la animación no se ejecuta. En la home (que sí usa `motion`) el efecto contrario: las secciones nacen en `opacity:0` sin fallback de `prefers-reduced-motion`.

Arreglo `Omit<BoxProps,'component'>` y no aceptar `component`; quitar `component="section"` de las 32 llamadas; envolver la app en `<MotionConfig reducedMotion="user">`.

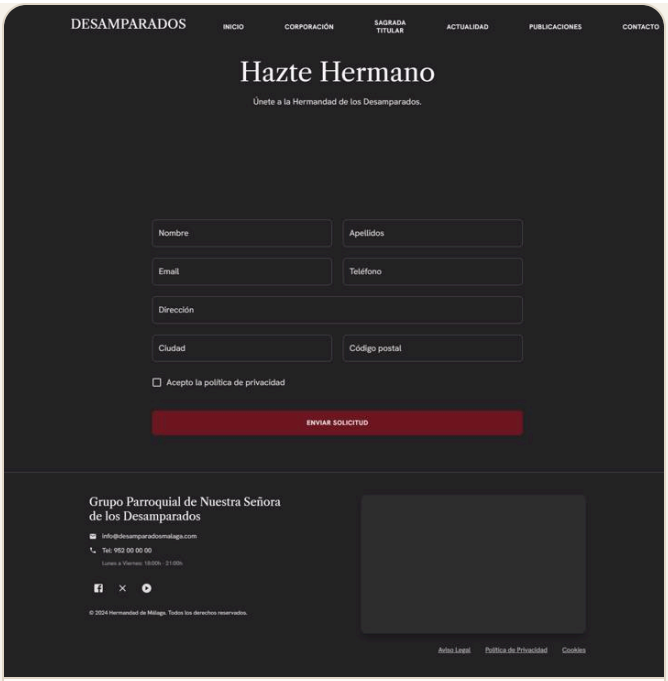
MÁS BUGS Y FORMULARIOS

SEV.	HALLAZGO	DÓNDE
Alta	Sin scroll-to-top al cambiar de ruta (las páginas aparecen con el scroll a mitad)	`routes/index.tsx`
Alta	El formulario "Hazte hermano" no encaja con `register`: falta password, DNI, fecha nac., isTutor	`members/public/schema.ts`
Alta	Login: valida `min(6)` (backend 8-64), no contempla el flujo `2FA_NEEDED`, no guarda token	`auth/schema.ts + LoginPage.tsx`

SEV.	HALLAZGO	DÓNDE
Alta	El store de auth no modela token/2FA/roles/perfiles múltiples; "sesión" = flag en localStorage	`auth/store.ts`
Media	Enlaces muertos `href="#"` (redes, YouTube, "descargar" publicaciones) en toda la web	`Navbar/Footer/QuickAccess`
Media	3 páginas huérfanas (Órganos de Gobierno, Boletines, Dossier) sin enlace desde ningún menú	`routes/index.tsx`
Media	`useCookieConsent` lanza si localStorage está bloqueado → pantalla en blanco (sin ErrorBoundary)	`hooks/useCookieConsent.ts`
Media	Banner de cookies: "Rechazar" no impide nada y reaparece en cada recarga	`useCookieConsent.ts:21-24`
Media	Accesos a `[0]` sin guarda: con datos reales, un hermano sin papeleta tumba la página	`PapeletaPage.tsx:9`

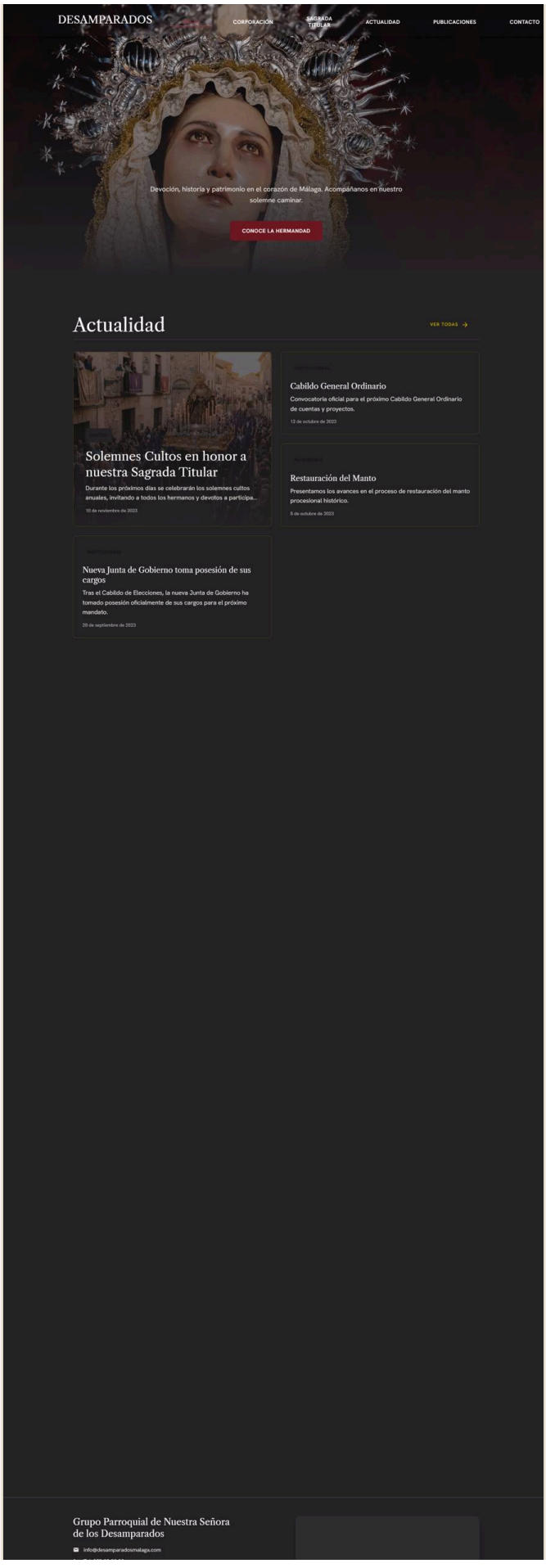
04 UI/UX y accesibilidad

El diseño es serio y coherente (paleta burdeos/dorado litúrgica, tipografía Caslon+Grotesk, modo oscuro cuidado). Estas capturas son del recorrido real que hice con el navegador. Los problemas están en contraste, responsive móvil y jerarquía semántica.



Hazte hermano

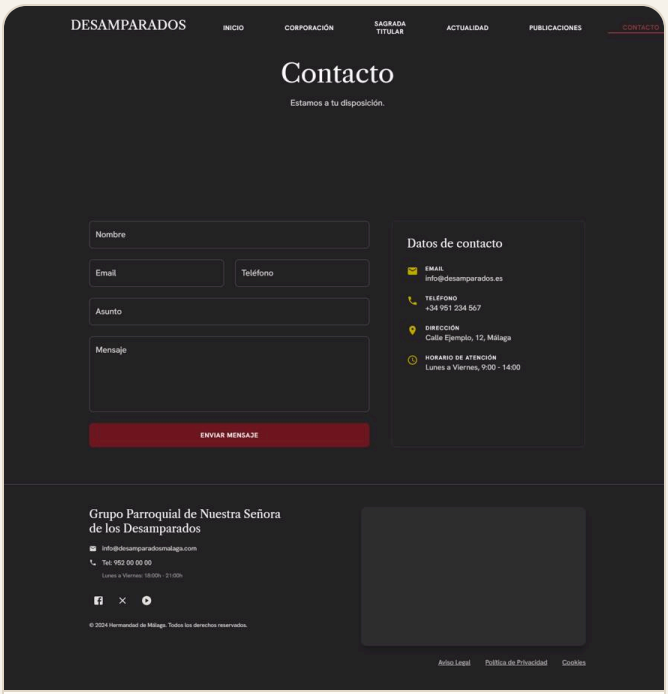
Bien maquetado y con consentimiento RGPD, pero le faltan password/DNI/fecha para encajar con la API.


DESAMPARADOS
CORPORACIÓN
SAGRADA TITULAR
ACTUALIDAD
PUBLICACIONES
CONTACTO
Devoción, historia y patrimonio en el corazón de Málaga. Acompáñanos en nuestro solemne caminar.
CONOCE LA HERMANDAD
Actualidad
VER TODAS
Solemnes Cultos en honor a nuestra Sagrada Titular
Durante los próximos días se celebrarán los solemnes cultos anuales, invitando a todos los hermanos y devotos a partícipa...
10 de noviembre de 2023
Cabildo General Ordinario
Convocatoria oficial para el próximo Cabildo General Ordinario de cuentas y proyectos.
12 de octubre de 2023
Restauración del Manto
Presentamos los avances en el proceso de restauración del manto procesional histórico.
5 de octubre de 2023
Nueva Junta de Gobierno toma posesión de sus cargos
Tras el Cabildo de Elecciones, la nueva Junta de Gobierno ha tomado posesión oficialmente de sus cargos para el próximo mandato.
25 de septiembre de 2023
Grupo Parroquial de Nuestra Señora de los Desamparados
info@desamparadosmalaga.com



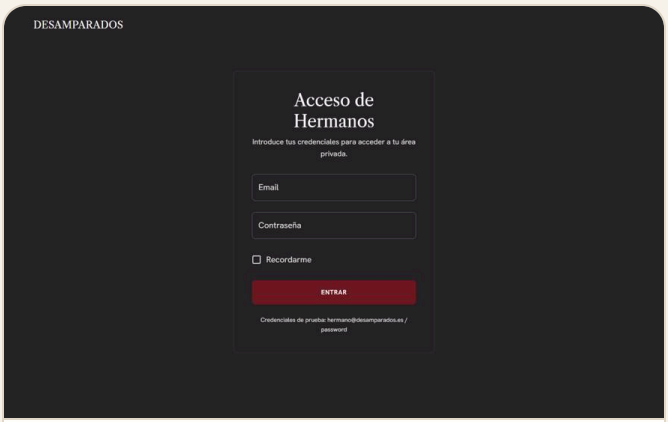
Home (escritorio)

Hero sólido; el hueco negro inferior es la animación en `opacity:0` que no dispara en captura completa.



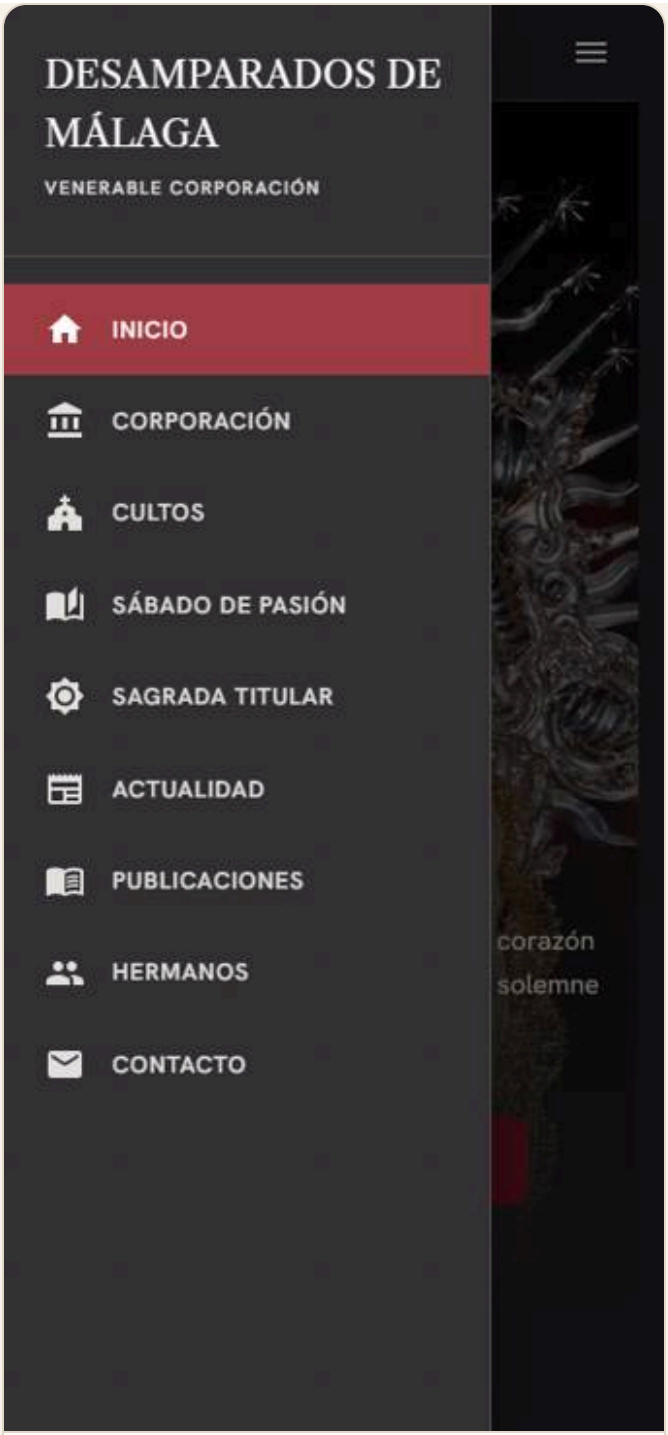
Contacto

Datos de relleno *incoherentes con el footer* y sin checkbox de consentimiento.



Login

Muestra al usuario final "Credenciales de prueba: hermano@desamparados.es / password".



Menú móvil

Limpio y funcional (verificado abriéndolo).



Home (móvil)

Barra de scroll horizontal:

+93px de desbordamiento

por la rejilla de accesos rápidos.

Desbordamiento horizontal en móvil: la rejilla de accesos usa 4 columnas fijas

CONFIRMADO

`QuickAccess.tsx:79 · gridTemplateColumns:'repeat(4,1fr)'`

Medido en el navegador a 375px: `scrollWidth 468` vs `viewport 375` = **93px de desbordamiento**, con barra de scroll lateral en toda la home. Culpables: los 8 iconos de QuickAccess forzados a 4 columnas.

Arreglo `gridTemplateColumns:{xs:'repeat(2,1fr)', md:'repeat(4,1fr)'}`.

Contraste insuficiente: burdeos como color de texto (~2,4:1) y badge de categoría casi invisible (~1,2:1)

ALTA

`theme/index.ts:80 · NewsCard.tsx:69-83`

`primary.main` (#a03d44) usado como texto sobre el fondo oscuro ronda 2,4:1 (mínimo AA 4,5:1); el badge de categoría en `NewsCard` pinta `#100e11` sobre `background.paper` ≈ 1,2:1.

Arreglo para texto usar el dorado (`secondary.main` ≈ 6,9:1) o un burdeos claro; reservar #a03d44/#6e1822 para fondos con texto blanco.

ACCESIBILIDAD Y UX (RESUMEN)

SEV.	HALLAZGO	DÓNDE
Alta	La home no tiene <h1> (está comentado) — mal para lectores de pantalla y SEO	`Hero.tsx:50-60`
Alta	"Credenciales de prueba" visibles al usuario final + login hardcodeado	`LoginPage.tsx:34,98`
Alta	Sin página 404: cualquier URL errónea devuelve la portada (soft-404 para buscadores)	`routes/index.tsx:132`
Media	Galería de imágenes no operable por teclado ni etiquetada	`ImageGallery.tsx:42-67`
Media	Animaciones sin `prefers-reduced-motion`; `scroll-behavior:smooth` global	`AnimatedSection / index.css`
Media	Jerarquía de encabezados con saltos (h2→h4) en varias páginas	`EventCard.tsx:24`

SEV.	HALLAZGO	DÓNDE
Media	Feedback de éxito de formularios fuera de la vista y sin foco (en móvil parece que falló)	`HazteHermano/Contact`
Baja	Sin "saltar al contenido"; textos de 10-12px con opacidad; iconos sociales incorrectos (X = ✕)	`varios`

05 SEO, legal y RGPD

Es una web pública que recoge datos personales: aquí hay obligaciones legales, no solo mejoras. Las páginas legales existen pero son plantillas genéricas.

Aviso legal sin NIF, dirección ni registro (LSSI art. 10)

Privacidad sin plazos, destinatarios ni mención a la AEPD

Cookies con consentimiento tácito ("al navegar acepta") no válido

Solo la home tiene **meta description**

Sin **404**, sin **robots.txt**, sin **sitemap**, sin **noindex** en el área privada

SPA sin prerender: HTML inicial vacío

Datos de contacto de relleno e incoherentes entre páginas

ALTA

`Footer.tsx vs ContactPage.tsx`

Verificado en el recorrido: email `info@desamparadosmalaga.com` (footer) vs `info@desamparados.es` (contacto); teléfono `952 00 00 00` vs `+34 951 234 567`; horario `18-21h` vs `9-14h`; dirección "Calle Ejemplo, 12"; mapa con coordenadas `0x0`; "© 2024" fijo. Además la denominación de la entidad varía (Grupo Parroquial / Hermandad y Cofradía / Venerable Corporación).

Arreglo un único `src/config/site.ts` (nombre legal, NIF, dirección, email, teléfono, redes, mapa) consumido por footer, contacto, legales y meta; año con `new Date().getFullYear()`.

Terceros que envían la IP sin consentimiento: el iframe de Google Maps (footer) y las Google Fonts (`index.html`) cargan antes de aceptar cookies. Para RGPD: cargar Maps solo tras aceptar (click-to-load) y auto-alojar las fuentes (`@fontsource`), lo que además mejora el rendimiento.

06 Rendimiento y DevOps

La imagen del hero pesa 4,98 MB y es el LCP de la home

CRÍTICA

`public/images/hero.jpg · 6720×4480 · 4.982.326 bytes`

Medido: 6720×4480 px, casi 5 MB, usado como `background-image` (no priorizable, sin `alt`) y reutilizado como miniatura en dos galerías. El resto de imágenes están bien (<75 KB). LCP de varios segundos en 4G.

Arreglo exportar a ≤1920px / ~200 KB (WebP/AVIF + fallback), `<img srcSet fetchpriority="high" alt>` + `preload`, y una miniatura aparte para las galerías.

Build ✓ (1,6s) · Tests ✓ (12/12) · Lint ✓ · `tsc` ✓

backend npm audit: 25 vulnerabilidades (15 altas) — `multer`, `nodemailer`, `prisma`, `path-to-regexp`…

frontend audit: **0 vulnerabilidades**

SEV.	HALLAZGO	DÓNDE
Alta	Navbar re-renderiza a ~60fps animando `backdrop-filter` (repintado de capa ancho completo)	`Navbar.tsx:72-102`
Alta	Imágenes sin `loading="lazy"`, `decoding="async"` ni dimensiones (CLS)	`NewsCard/PublicationCard…`
Media	`npm audit` del backend con 15 vulnerabilidades altas (deps directas: multer, nodemailer)	`package.json`
Media	`.dockerignore` no excluye `.env*/storage/`; `Dockerfile.prod` hace `COPY . .`	`.dockerignore`
Media	Google Fonts render-blocking + externo (RGPD)	`index.html:9-11`
Baja	25 tests e2e (.mjs) no idempotentes, sin asserts en 2 de 3, mutan config real y bloquean cuentas	`test_e2e_*.mjs`
Baja	backend sin script de test real ni build (ejecuta `tsx` en prod); README es la plantilla de Vite	`package.json`

07 Plan de acción priorizado

Orden recomendado. La fase 0 es innegociable antes de exponer nada a internet.

Fase 0 · Hoy

- **Cerrar el mass assignment**: lista blanca en `prepareUpdateData` + `"+": "delete"` global en ArkType. *Dos líneas, tapa el agujero crítico.*
- **Quitar los secretos** de `/admin/solicitudes` (`select` explícito + `omit` en el cliente Prisma).
- **Retirar** las credenciales de prueba visibles del login.

Fase 1 · Semana 1

- **Cablear el frontend al backend**: capa `src/lib/api`, hooks de datos, store de auth con token/2FA/roles, estados loading/error/vacío.
- **Arreglar la navegación de noticias** (página de detalle + 404 real) y el `AnimatedSection` de las 32 páginas.
- **Blindar**: borradores públicos, bajas que tumban al ADMIN, reset de contraseña, ClamAV.
- **Responsive móvil** (rejilla QuickAccess) y contraste AA.

Fase 2 · Semana 2

- **Lógica de negocio**: máquina de estados de recibos, reordenar censo, importes en `Decimal`, método de pago, apuntes en `Transaccion`.
- **Legal/RGPD real**: aviso legal con NIF/dirección, privacidad completa, cookies con consentimiento previo; centralizar datos en `site.ts`.
- **Rendimiento**: optimizar `hero.jpg`, `loading="lazy"`, auto-alojar fuentes, Navbar sin re-render por frame.
- `npm audit fix` del backend y montar (o eliminar) `procesion/transaccion`.

Fase 3 · Continuo

- SEO (meta por página, sitemap, robots, prerender), accesibilidad (h1, teclado, 404), tests reales (suite backend con supertest; front con MSW y regresiones de los bugs de arriba), CI, y limpieza de código muerto/placeholders.

08 Lo que está bien hecho

No todo son problemas: hay decisiones sólidas que conviene conservar.

Base de seguridad seria

Helmet (CSP/HSTS/nosniff), rate-limit por IP + lockout por cuenta, JWT con algoritmo fijado, revalidación de sesión contra BD con rol fresco.

Propiedad verificada (anti-IDOR)

Comprobé en vivo que un usuario no puede leer ni tocar fichas/recibos de otra familia (403).

2FA y RGPD reales

TOTP con códigos de respaldo de un solo uso, auditoría de acciones sensibles, exportación y anonimización de datos propios.

Sanitización HTML correcta

sanitize-html con allowlist estricta que neutraliza `<script>`, `javascript:`, `onerror`, `iframe` — verificado.

Frontend bien estructurado

code-splitting por ruta, tema con tokens, RHF+zod, modo oscuro coherente, build y tests verdes.

Diseño con criterio

paleta litúrgica burdeos/dorado, tipografía Caslon+Grotesk, dependencias del front sin vulnerabilidades.

Cómo se hizo esta auditoría. Lectura línea a línea de los ~12.800 renglones de código (3 auditorías en paralelo). Para verificar los hallazgos de seguridad levanté un entorno real: MariaDB 10.11 portable con datos sembrados, la API en `:3001` y la web en `:5174`, y ejecuté los ataques contra la BD real y un navegador Chromium. Todos los datos de prueba se limpiaron y los servicios se detuvieron al terminar; el repositorio quedó intacto.

Las cifras del panel son la suma de las tres auditorías; hay solape entre algunos hallazgos (p. ej. el mass assignment aparece en varios módulos). Las etiquetas **Confirmado** marcan lo reproducido en vivo, no solo leído en el código.